

AWS re:Invent

NOV. 28 – DEC. 2, 2022 | LAS VEGAS, NV

BOA102

Start Building! Secure your serverless applications on AWS

Haowen Huang

Senior Developer Advocate
Amazon Web Services

Betty Zheng

Senior Developer Advocate
Amazon Web Services



© 2022, Amazon Web Services, Inc. or its affiliates. All rights reserved.

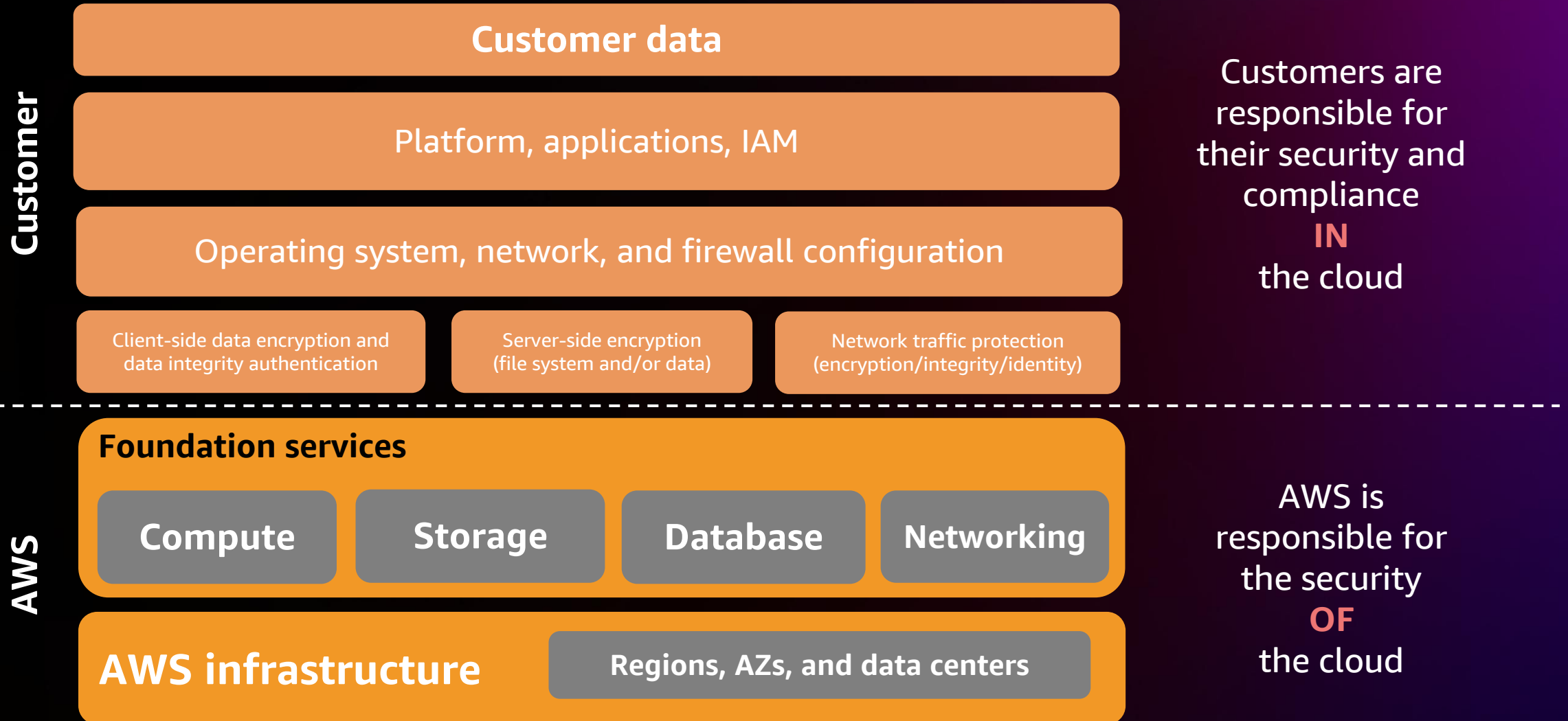
Agenda

- Understand shared responsibility with AWS
- How to think about serverless security
- Zero-trust principles in practice of serverless security
- Summary & discussion

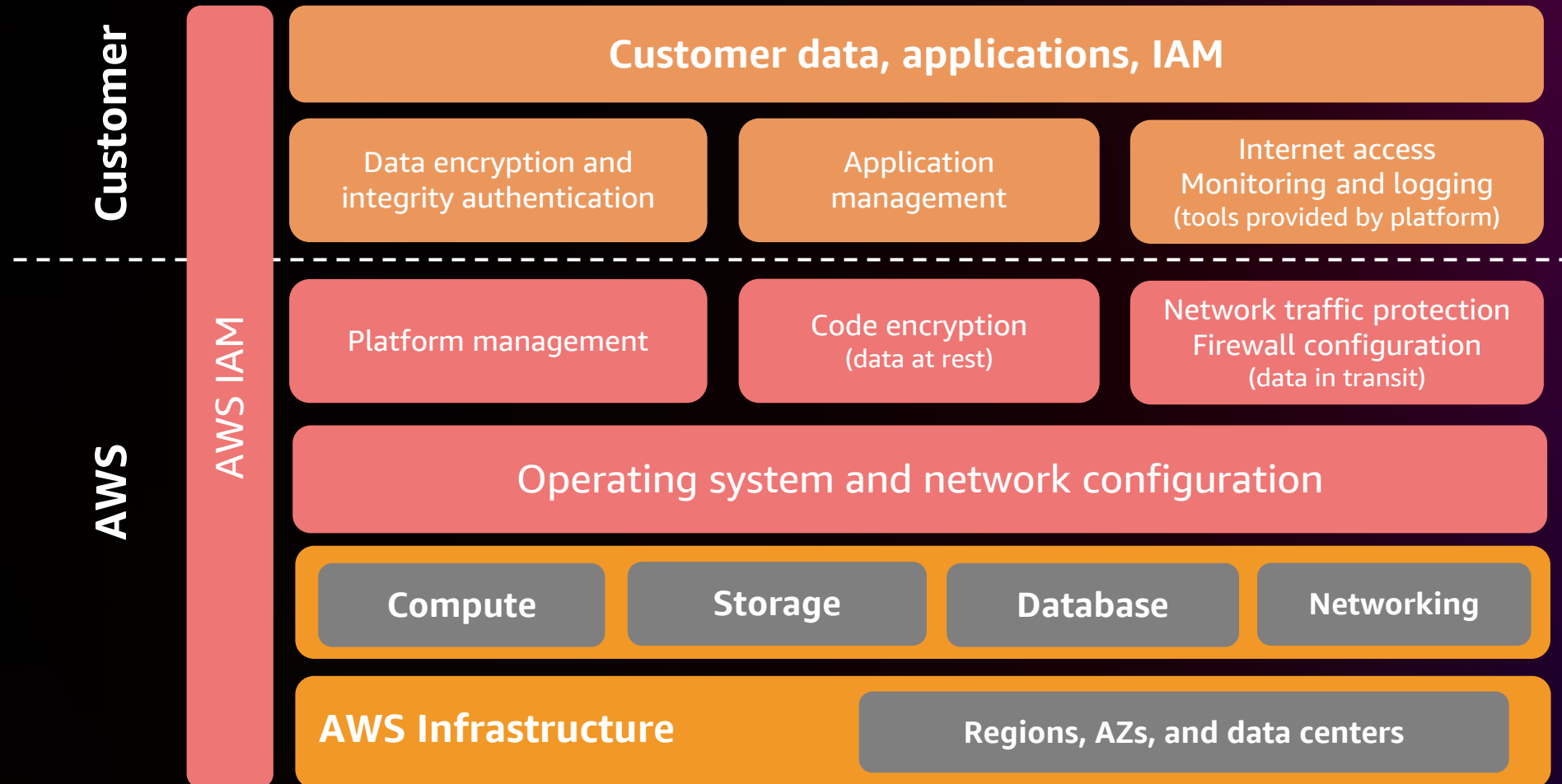
Understand shared responsibility with AWS



Shared responsibility with AWS



With serverless, AWS takes a greater share of responsibility



How to think about serverless security



“Traditional” vs. modern security



Zero-trust principles in practice of serverless security

Zero Trust, defined

Zero Trust is a conceptual **model** and an associated set of **mechanisms** that focus on providing security controls around digital assets that **do not solely or fundamentally depend** on traditional network controls or network perimeters.

Never trust, always verify

[Zero Trust architectures: An AWS perspective](#)



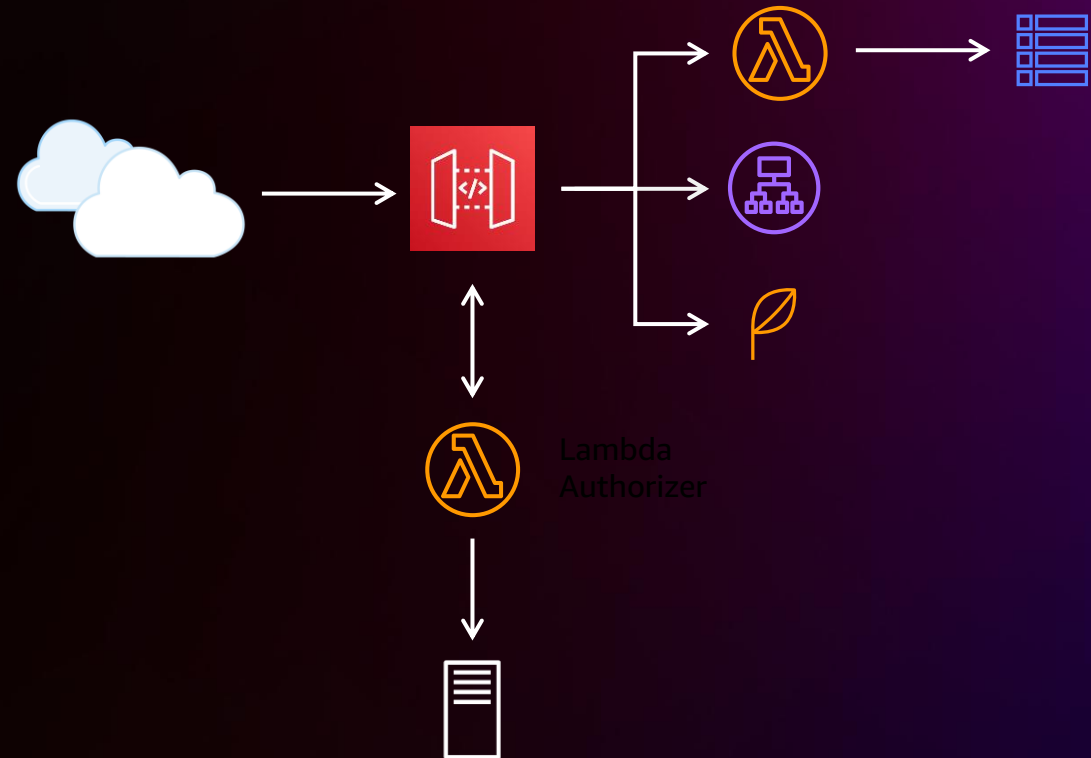
Zero Trust Principle #1

Use permissions and user behavior analysis to **authenticate and authorize each action**—not just at the start of a “session”

Best practice 1: Authentication & authorization

USE AUTHENTICATION AND AUTHORIZATION MECHANISMS

- Amazon API Gateway supports **multiple mechanisms** to control access (fine-grained)
- Integrate with variety of identity providers
 - Amazon Cognito user pools
 - OIDC, OAuth (JWT authorizer)
 - IAM
 - Lambda authorizer (custom)

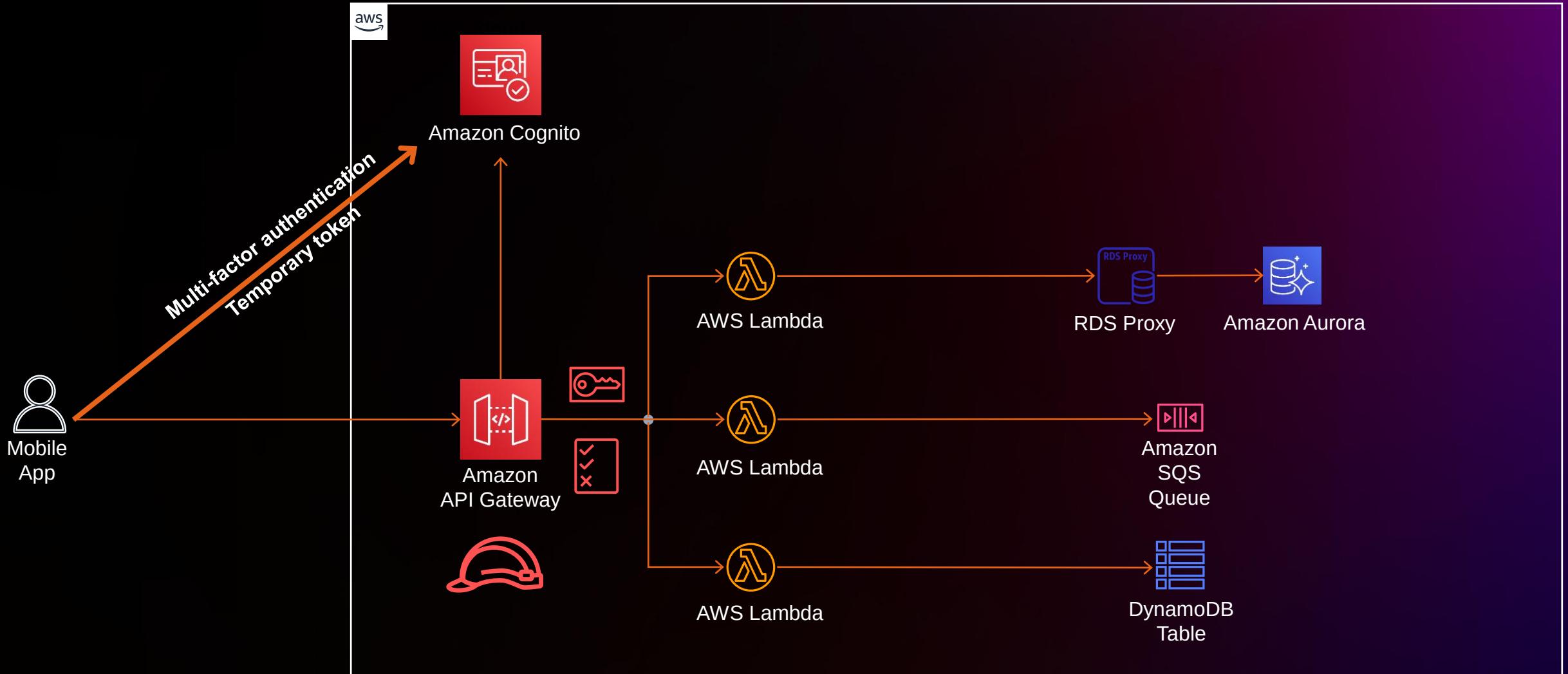


Zero Trust Principle #2

Service-to-service **communication should be consistent** and follow best practices, regardless of whether either party is **another service or a human interface**



Zero Trust Principle #2



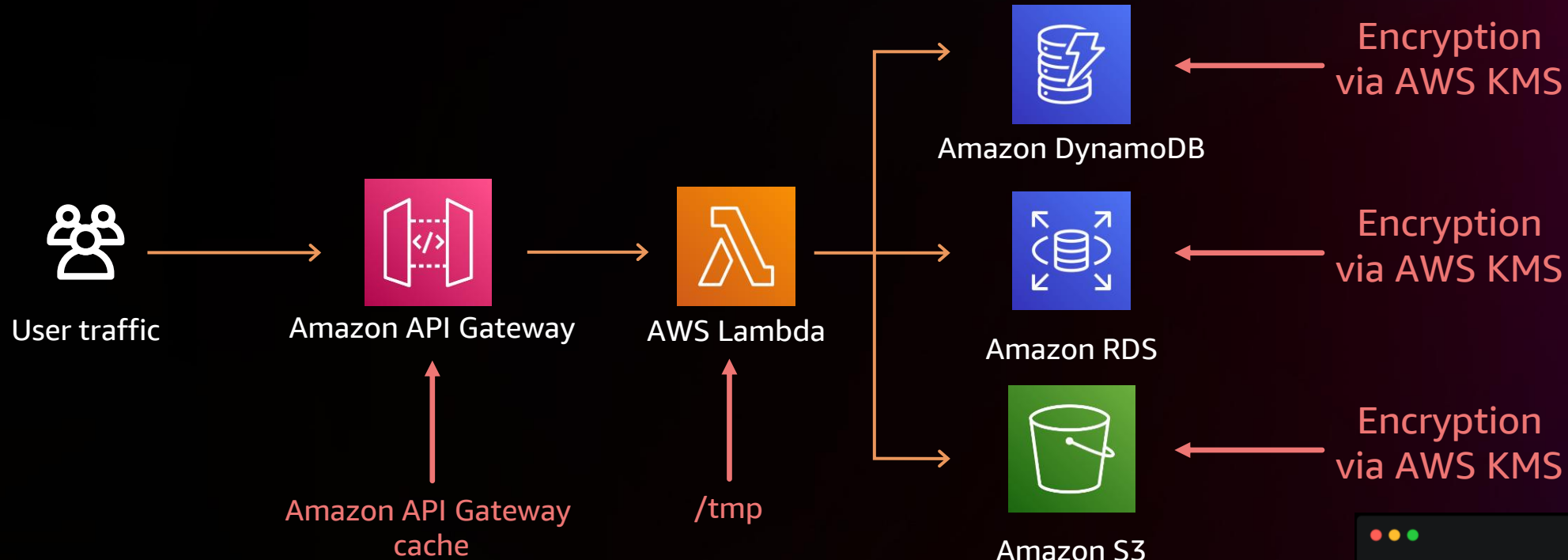
Zero Trust Principle #3

Leverage scalable endpoints and **network encryption** over all communications channels

**“Dance like nobody’s watching,
encrypt like everybody is” --Werner Vogels**

Best practice 2: Data encryption and integrity

PROTECT DATA AT REST



```
Resources:
  MyDynamoTable:
    Type: 'AWS::DynamoDB::Table'
    Properties:
      SSESpecification:
        SSEEnabled: True
        SSEType: 'KMS'
        KMSMasterKeyId: <KMSKeyId>
```

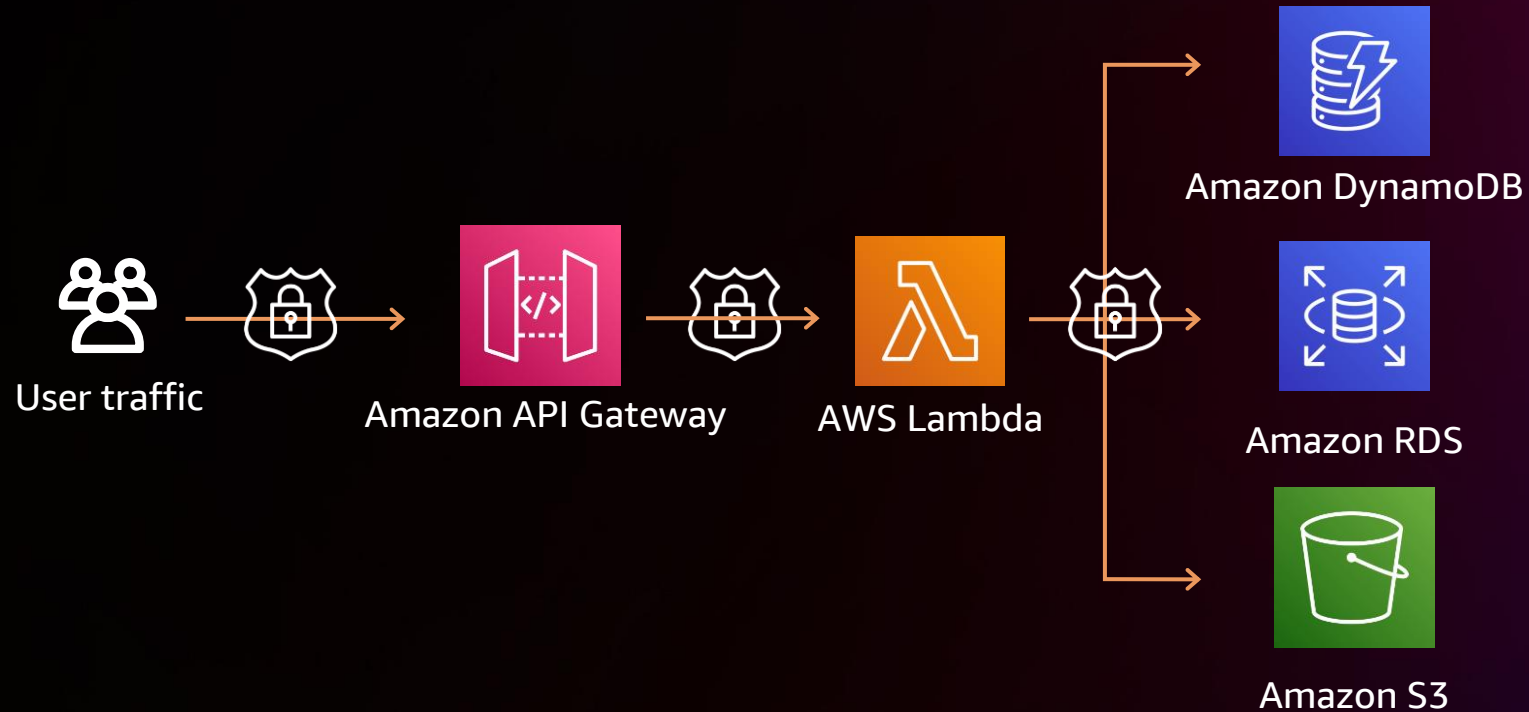
```
AuroraDBCluster:
  Type: AWS::RDS::DBCluster
  Properties:
    ...
    StorageEncrypted: True
    KmsKeyId: !Ref AuroraKMScmk
```

```
Resources:
  EncryptedS3Bucket:
    Type: 'AWS::S3::Bucket'
    Properties:
      BucketName: 'encryptedbucket-${AWS::AccountId}'
      BucketEncryption:
        ServerSideEncryptionConfiguration:
          - ServerSideEncryptionByDefault:
              SSEAlgorithm: 'aws:kms'
              KMSMasterKeyId: '234abcd-12ab-34cd-56ef-1234567890ab'
      DeletionPolicy: Delete
```



Best practice 2: Data encryption and integrity

PROTECT DATA IN TRANSIT



Zero Trust Principle #4/#5

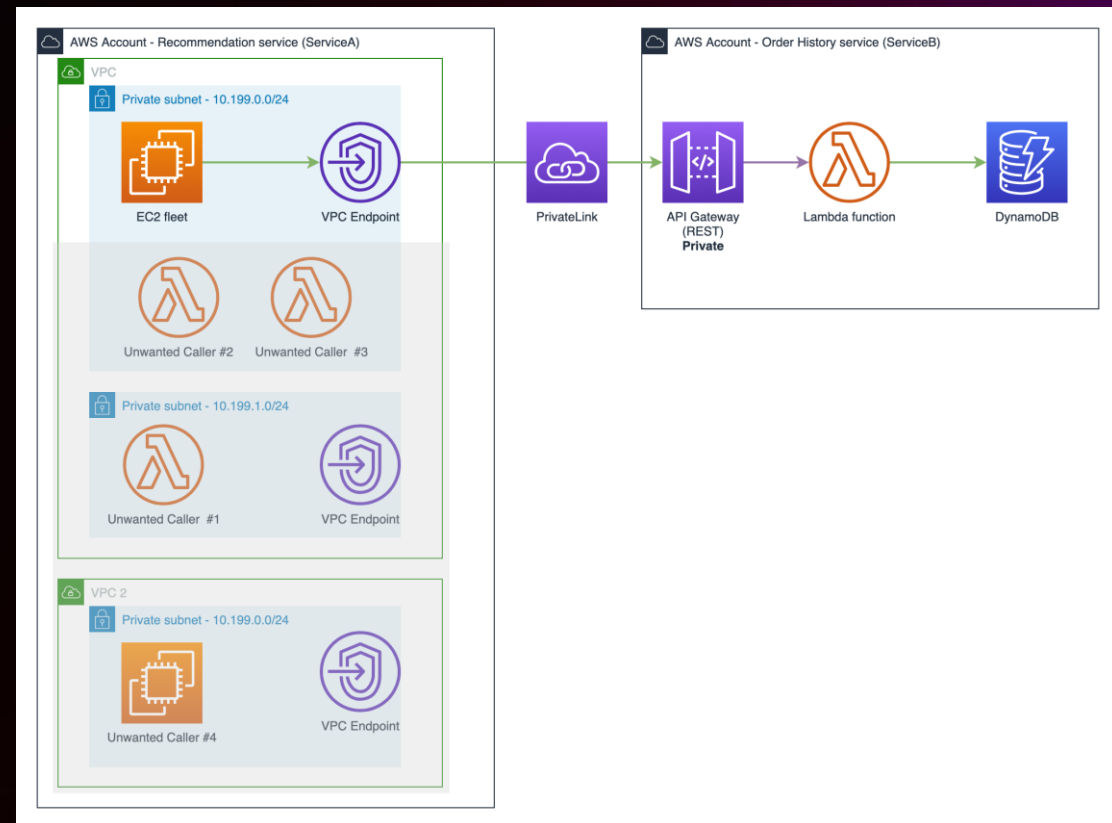
#4 Eliminate unnecessary pathways between resources

#5 When appropriate, leverage gateways to manage communication between components

Who are the unwanted callers?

- Expected Caller - Unknown API
- Unwanted caller #1
- Unwanted caller #2
- Unwanted caller #3
- Unwanted caller #4

<https://zerotrust-service2service.workshop.aws>



Zero Trust Principle #4/#5 (Cont.)

#4 Eliminate unnecessary pathways between resources

#5 When appropriate, leverage gateways to manage communication between components

Workshop tasks overview:

- Task #1: API Gateway Authorization - SigV4 way! (hit on principle 1&2)
- Task #2: API Gateway Resource Policy (hit on principle 4)
- Task #3: VPC Endpoint Policy (hit on principle 4&5)
- Task #4: VPC Endpoint Security Group (hit on principle 3)

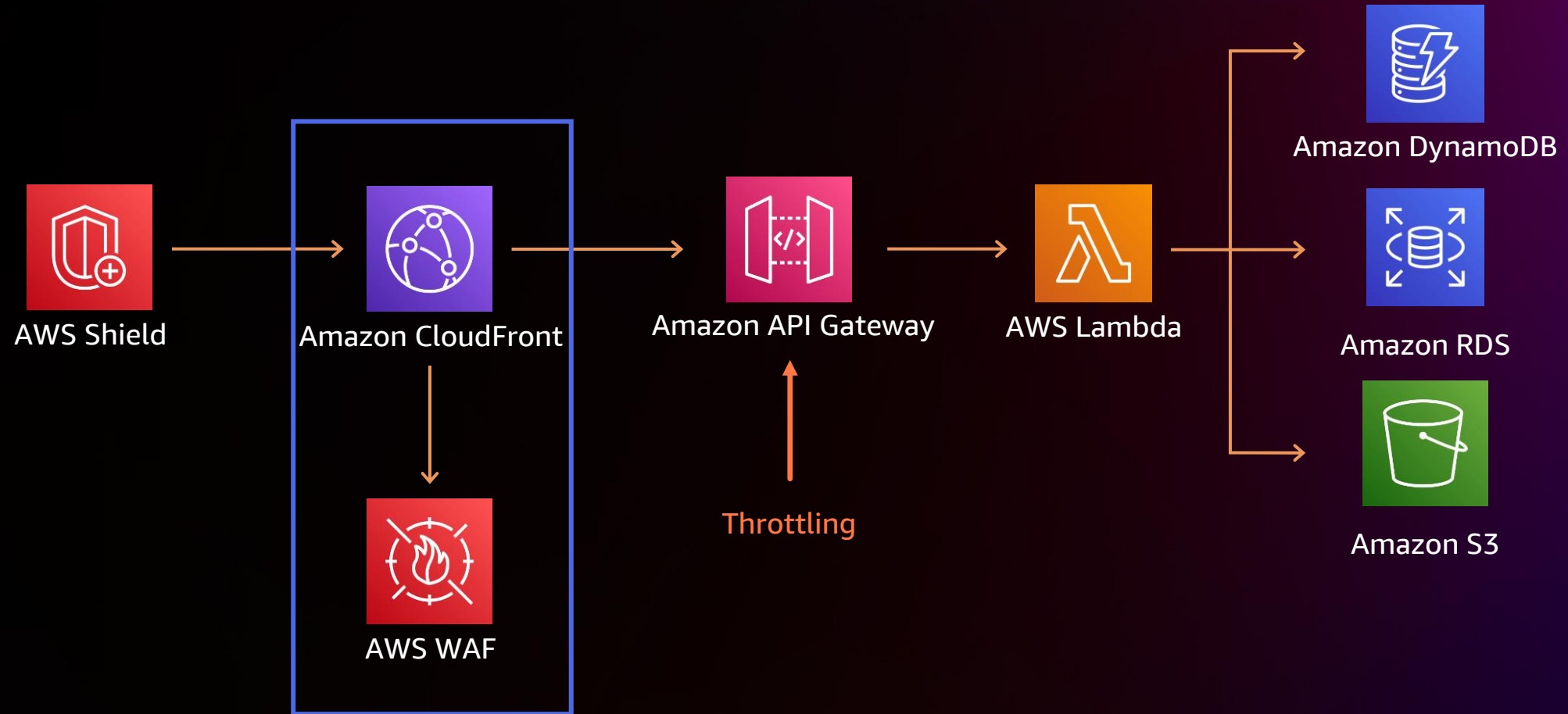
<https://zerotrust-service2service.workshop.aws>



Zero Trust Principle #6

Enforce **the right amount of security** at the point of access

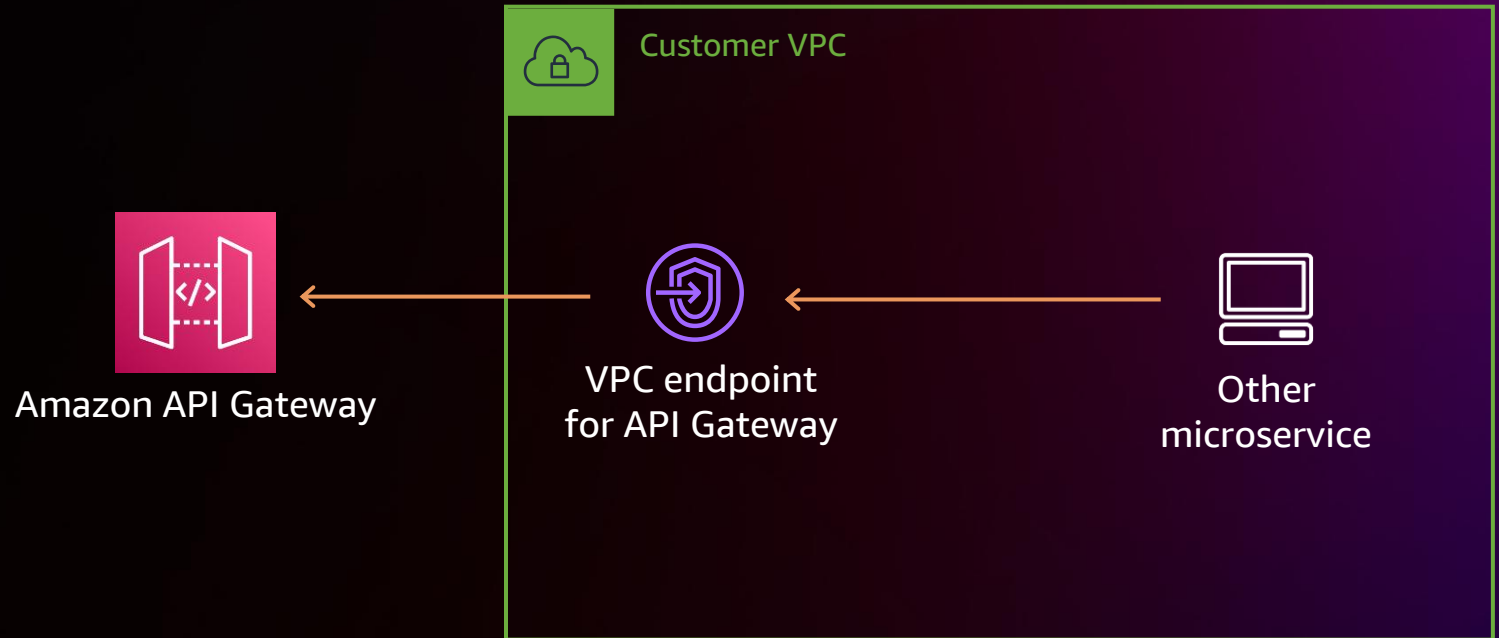
Best practice 3: Denial of service & Infra protection



Best practice 3: Denial of service & Infra protection

PRIVATE AMAZON API GATEWAY ENDPOINT

- Restrict access to services and resources inside your VPC
- Uses interface VPC endpoint
- Attach resource policy to API Gateway to limit allowed VPCs



Zero Trust Principle #7

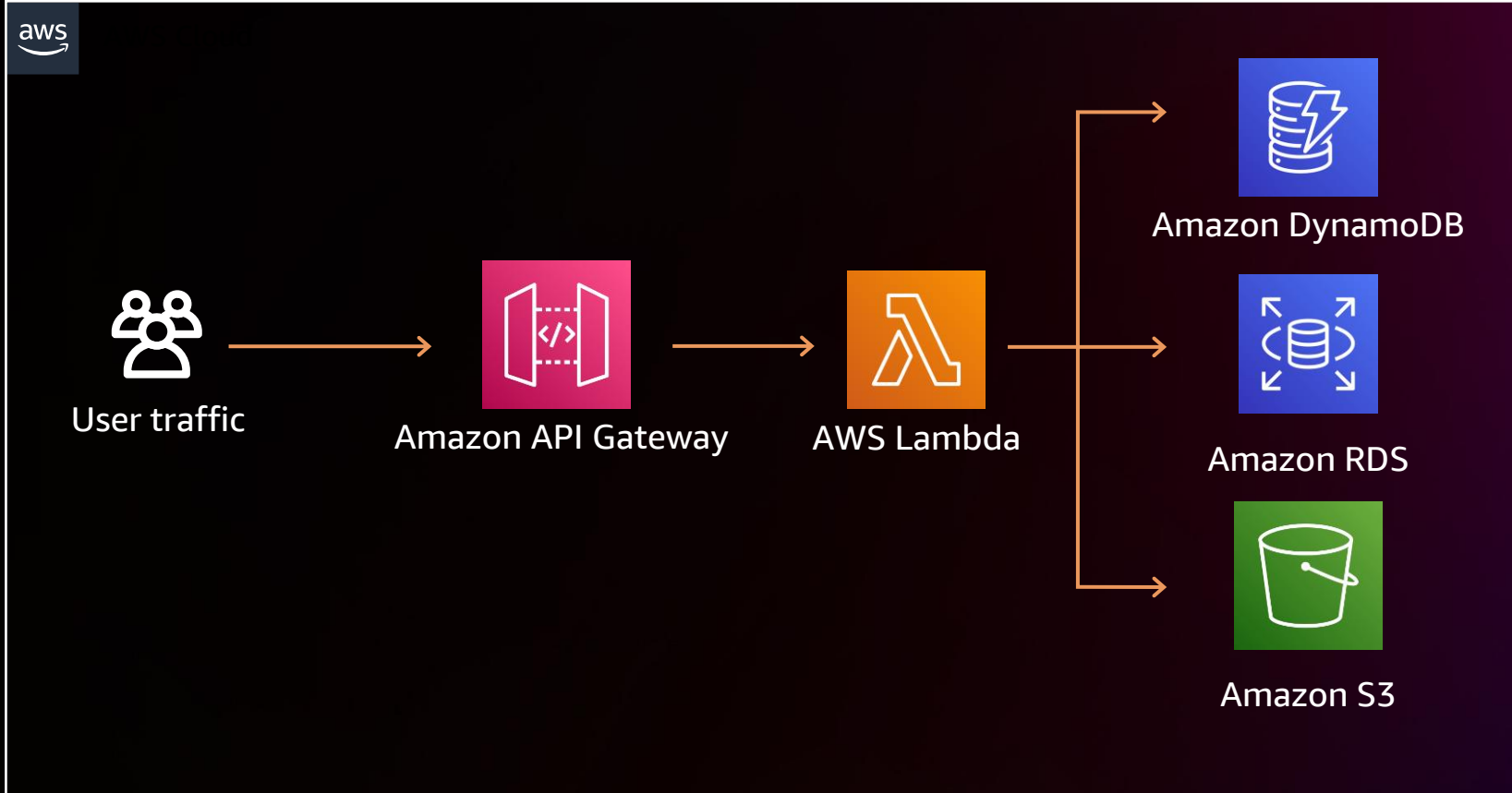
Identify all assets uniquely, provide the right permissions, and then **be vigilant with monitoring** and maintenance

Best practice 4: Monitoring, logging, and configuration management

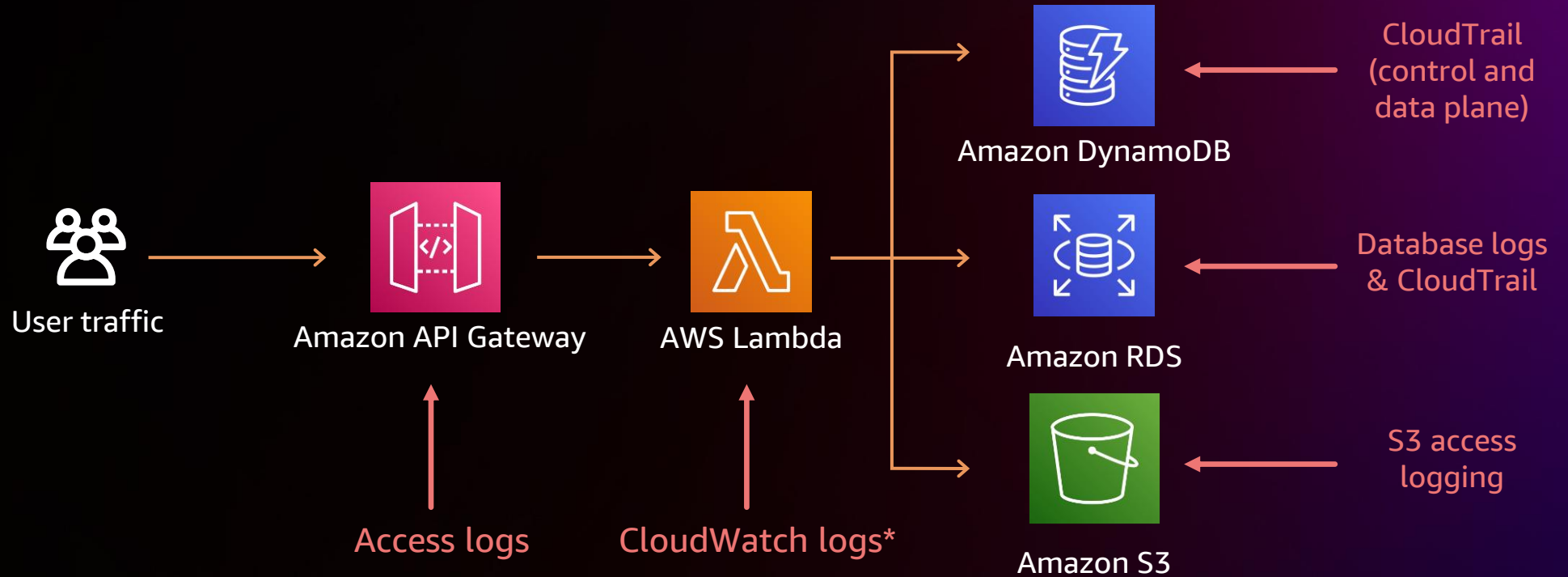


Amazon CloudWatch

- Metrics
- Alarms
- Dashboards
- Logging

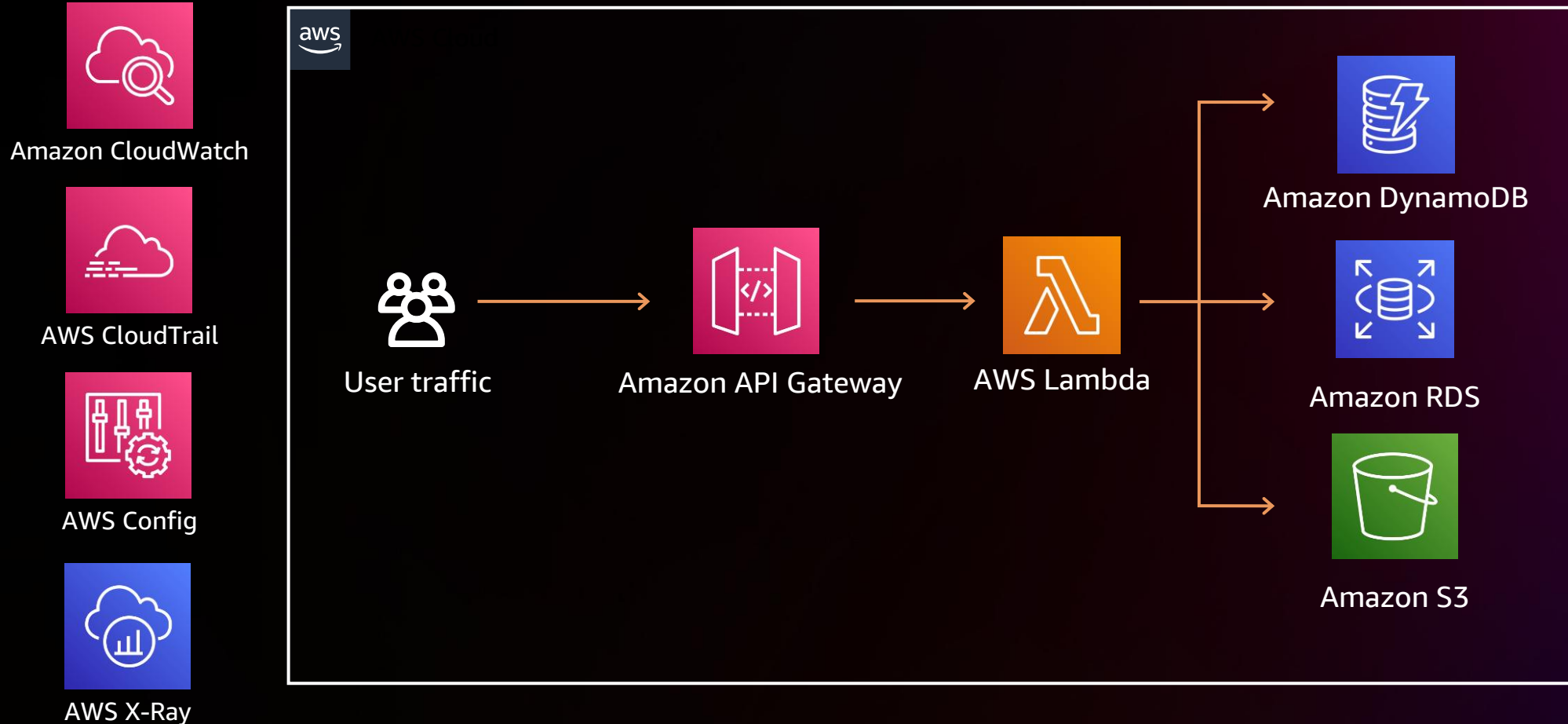


Best practice 4: Monitoring, logging, and configuration management



*Help ensure Lambda function execution role has permissions to CloudWatch

Best practice 4: Monitoring, logging, and configuration management



Serverless security best practices

SUMMARY

- Authentication and authorization
- Data encryption and integrity
- Denial of service and infrastructure protection
- Monitoring, logging, and configuration management

Additional resources

Zero Trust architectures: An AWS perspective:

<https://aws.amazon.com/cn/blogs/security/zero-trust-architectures-an-aws-perspective/>

Serverless Applications Lens – AWS Well-Architected Framework Security Pillar:

<https://docs.aws.amazon.com/wellarchitected/latest/serverless-applications-lens/welcome.html>

Zero Trust Workshop: [https://catalog.us-east-](https://catalog.us-east-1.prod.workshops.aws/workshops/dc413216-deab-4371-9e4a-879a4f14233d/en-US)

[1.prod.workshops.aws/workshops/dc413216-deab-4371-9e4a-879a4f14233d/en-US](https://catalog.us-east-1.prod.workshops.aws/workshops/dc413216-deab-4371-9e4a-879a4f14233d/en-US)



Thank you!



Please complete the session survey in the **mobile app**

